

Informe Ejecutivo RGPD

Novedades legales y regulatorias

STS 1590/2026 refuerza que el tratamiento empieza antes de recopilar el dato | 2026-04-28 | AEPD blog | Impacto Alto

Hecho confirmado: La AEPD resume que la solicitud de datos personales forma parte del tratamiento y que el cumplimiento debe comenzar en el diseño previo del tratamiento.

Interpretación: Eleva el riesgo de formularios, procesos de onboarding y peticiones documentales mal justificadas desde su fase de diseño.

Riesgo estimado: Mayor exposición en RR. HH., compliance, salud laboral y sector público.

Recomendación automática: Revisar minimización, proporcionalidad y base jurídica antes de pedir nuevos datos.

<https://www.aepd.es/prensa-y-comunicacion/blog/en-que-momento-comienza-legalmente-un-tratamiento-de-datos-personales>

AEPD activa participación española en la acción europea 2026 sobre transparencia | 2026-03-19 | AEPD | Impacto Alto

Hecho confirmado: La AEPD analizará prácticas de responsables públicos y privados sobre artículos 12, 13 y 14 RGPD.

Interpretación: Es una señal directa de que avisos de privacidad, capas informativas y trazabilidad del deber de información pueden ser objeto de contraste supervisor.

Riesgo estimado: Alto para ecosistemas multiweb, apps y proveedores con datos de terceros.

Recomendación automática: Auditar hoy cláusulas informativas, lógica de capas y evidencia de entrega.

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-aepd-participa-en-accion-europea-analizar-transparencia>

EDPB abre CEF 2026 sobre transparencia e información | 2026-03-19 | EDPB | Impacto Alto

Hecho confirmado: 25 autoridades europeas participarán en acciones de enforcement o fact-finding sobre obligaciones de transparencia.

Interpretación: El riesgo ya no es teórico: la transparencia pasa a ser tema de supervisión coordinada paneuropea.

Riesgo estimado: Especialmente relevante para empleo, marketing, proveedores cloud y datos obtenidos indirectamente.

Recomendación automática: Alinear avisos, registros de actividades y fuentes de datos de terceros.

https://www.edpb.europa.eu/news/news/2026/cef-2026-edpb-launches-coordinated-enforcement-action-transparency-and-information_en

Guidelines 1/2026 sobre investigación científica en consulta pública | 2026-04-17 | AEPD/EDPB | Impacto Medio-Alto

Hecho confirmado: El EDPB sometió a consulta sus directrices sobre investigación científica hasta el 25 de junio de 2026.

Interpretación: Afecta a reutilización secundaria de datos, consentimiento amplio y gobernanza de proyectos con IA.

Riesgo estimado: Medio-Alto para salud, biotech, analytics y entornos universitarios.

Recomendación automática: Revisar gobernanza de reutilización de datos y compatibilidad de fines.

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/comite-europeo-somete-a-consulta-publica-sus-directrices-sobre-tratamiento-con-fines-investigacion-cientifica>

EDPB y EDPS piden equilibrio entre ciberseguridad y privacidad en CSA2/NIS2 | 2026-03-19 | EDPB/EDPS | Impacto Medio-Alto

Hecho confirmado: Respaldan un punto único de entrada para notificar brechas y piden que los controles de ciberseguridad no desborden el principio de necesidad.

Interpretación: Las empresas tendrán más presión para coordinar compliance NIS2 y RGPD sin duplicar ni sobreactuar los tratamientos.

Riesgo estimado: Relevante para operadores esenciales e importantes y su cadena TIC.

Recomendación automática: Unificar hoy la matriz de incidentes, brechas y escalado legal.

https://www.edpb.europa.eu/news/news/2026/edpb-and-edps-support-strengthening-eus-cybersecurity-and-easing-compliance-while_en

Brasil obtiene decision de adecuacion UE | 2026-01-28 | DOUE/BOE | Impacto Medio

Hecho confirmado: La Comision declaro adecuado el nivel de proteccion de Brasil conforme al articulo 45 RGPD.

Interpretacion: Reduce friccion en determinadas transferencias, pero no sustituye la evaluacion de proveedores y contratos.

Riesgo estimado: Medio para empresas con servicios regionales, BPO o soporte LATAM.

Recomendacion automatica: Actualizar mapa de transferencias y distinguir adecuacion, SCC y DPF.

<https://www.boe.es/buscar/doc.php?id=DOUE-L-2026-80106>

Incidentes y brechas recientes

Fecha	Tipo	Severidad	Descripcion	Estado
2026-05-14	brecha de datos	alta	INCIBE-CERT publica incidente en la agencia francesa France Cybersecurity Agency (ANSSI) con unos datos de clientes de un banco de 10 millones de euros.	Resuelto
2026-05-19	encargado de tratamiento comprometido	alta	INCIBE-CERT recoge el incidente de Instructure/Canvas con exposición de datos académicos y más de 10 millones de usuarios.	Resuelto
2026-01-13	acceso no autorizado	alta	INCIBE informa de filtración comunicada por Endesa a clientes de la compañía de energía eléctrica.	Resuelto

Sanciones y resoluciones de referencia

Entidad	Motivo	Importe	Leccion aprendida
Xfera Moviles S.A.	brecha de confidencialidad por ciberataque	4.000.000 EUR	Seguridad insuficiente y deber de integridad in
Centros Comerciales Carrefour, S.A.	brecha de datos con incumplimientos de arts. 5.1.f, 32 y 34 RGPD	320.000 EUR	No basta con contener la brecha: también se s
Universitat Internacional Valenciana	uso de biometría e IA en exámenes online sin exce	650.000 EUR	Biometría e IA + ausencia de alternativa meno
Ayuntamiento no identificado en crisis de COVID	notificación revelaban información de em	50.000 EUR	Seguimiento de la información pública y fal

Riesgo por area

Area	Nivel	Lectura ejecutiva
Gestion de datos personales	Medio-Alto	Presion sobre minimizacion y base juridica desde el diseno
Derechos de los interesados	Alto	Transparencia, acceso y supresion siguen en foco europeo
Seguridad de la informacion	Alto	Brechas recientes y sanciones de referencia elevadas
Encargados de tratamiento	Alto	Riesgo de subencargados y SaaS criticos
Transferencias internacionales	Medio	Brasil mejora contexto, EE. UU. y terceros paises siguen vigilados
Documentacion y politicas	Medio-Alto	Se necesita prueba de cumplimiento operativo
Registro de actividades	Medio	Debe alinearse con transparencia y fines reales
Evaluaciones DPIA	Alto	Prioridad en IA, biometria, menores y observacion sistematica
Consentimiento	Medio-Alto	Cookies y reutilizacion secundaria siguen sensibles
Cookies	Medio-Alto	Digital Omnibus y fatiga de banners mantienen presion
Formacion y concienciacion	Alto	Fraude, phishing y error humano siguen activos
Notificacion de brechas	Alto	Riesgo juridico fuerte si falla la evaluacion o la comunicacion

Paneles operativos

Bloque	Lectura clave
Derechos	Acceso: riesgo medio-alto; SLA: mantener respuesta dentro de 30 dias
DPIA	Pendientes: recomendado revisar cartera de IA, biometria, menores y tracking intensivo
Transferencias	Adecuacion: Brasil confirmado; revisar proveedores aplicables
Cookies	Banner: revisar configuracion granular; Riesgo terceros: alto si no hay inventario y bloqueo previo
Encargados	Proveedores criticos: educacion cloud, CRM, marketing, soporte TI
Formacion	Riesgo: alto si no hay reciclaje reciente; Areas: phishing, deber de secreto, brechas, minimizacion

Recomendaciones clave

Prioridad	Accion
Critica	Auditar hoy los avisos de privacidad, capas informativas y evidencia de entrega en web, formularios y HR.
Critica	Verificar el playbook de brechas: deteccion, evaluacion 72h, decision de comunicar y plantilla para afectados.
Alta	Revisar contratos de encargo y subencargados de SaaS criticos, especialmente educacion, marketing, soporte y analitica.
Alta	Confirmar si existen tratamientos con biometria, IA o menores sin DPIA vigente y con alternativas menos invasivas.
Alta	Actualizar el mapa de transferencias internacionales distinguiendo adecuacion, SCC, DPF y excepciones.
Media	Revisar cookies de terceros y granularidad real del banner conforme a la guia AEPD.
Media	Lanzar microformacion interna sobre phishing con datos personales y canales de escalado.
Baja	Preparar posicion interna para futuras simplificaciones regulatorias sin rebajar controles esenciales.

Seccion IA

Riesgo RGPD estimado: 61/100 - moderado alto

Areas de mayor exposicion: transparencia, brechas, encargados, IA y biometria, transferencias

Impacto empresarial: posible incremento de exposicion en ventas, HR, atencion al cliente, marketing y proveedores cloud

- mas supervision europea sobre transparencia y fuentes indirectas de datos
- continuidad sancionadora en seguridad, notificacion y contratos de encargo
- mayor escrutinio de reutilizacion de datos con fines de investigacion e IA

Prediccion analitica generada por IA; no constituye hecho confirmado.

Fuentes principales

2026-04-28 - AEPD blog - momento de inicio del tratamiento

<https://www.aepd.es/prensa-y-comunicacion/blog/en-que-momento-comienza-legalmente-un-tratamiento-de-datos-personales>

2026-03-19 - AEPD - accion europea sobre transparencia

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-aepd-participa-en-accion-europea-analizar-transparencia>

2026-03-19 - EDPB - CEF 2026 transparencia

https://www.edpb.europa.eu/news/news/2026/edpb-2026-edpb-launches-coordinated-enforcement-action-transparency-and-information_en

2026-04-17 - AEPD - directrices investigacion cientifica

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/comite-europeo-somete-a-consulta-publica-sus-directrices-sobre-tratamiento-con-fines-investigacion-cientifica>

2026-03-19 - EDPB/EDPS - opinion conjunta CSA2/NIS2

https://www.edpb.europa.eu/news/news/2026/edpb-and-edps-support-strengthening-eus-cybersecurity-and-easing-compliance-while_en

2026-03-25 - AEPD - plan de actuacion 2026

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/agencia-publica-su-plan-actuacion-2026-y-el-informe-cumplimiento-iniciativas-2025>

2026-03-23 - AEPD - decálogo plataformas educativas

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/las-autoridades-proteccion-datos-publican-decalogo-contratacion-plataformas-educativas>

2026-01-28 - BOE/DOUE - decision de adecuacion Brasil

<https://www.boe.es/buscar/doc.php?id=DOUE-L-2026-80106>

2026-05-14 - INCIBE-CERT - France Titres

<https://www.incibe.es/incibe-cert/publicaciones/bitacora-de-seguridad/incidente-de-seguridad-en-la-agencia-nacional-de-identidad-digital-de>

2026-05-19 - INCIBE-CERT - Instructure Canvas

<https://www.incibe.es/incibe-cert/publicaciones/bitacora-de-seguridad/incidente-de-seguridad-digital-en-instructure-y-su-impacto-en-la>

2026-01-13 - INCIBE - Endesa

<https://www.incibe.es/index.php/node/599026>

2026-02-09 - INCIBE - Balance de Ciberseguridad 2025

https://www.incibe.es/sites/default/files/2026-02/Balance%20de%20ciberseguridad%202025%20INCIBE/BalanceCiberseguridad2025_INCIBE.pdf

2026-05 - AEPD - Memoria 2025

<https://www.aepd.es/memorias/memoria-aepd-2025.pdf>

2025-11-27 - AEPD - confidencialidad en sobres de notificacion

<https://www.aepd.es/informes-y-resoluciones/criterios-juridicos-aepd/sobres-de-notificacion-no-deben-revelar-informacion-sobre-su-contenido>

Este informe ha sido generado automaticamente mediante sistemas avanzados de inteligencia artificial y analisis de datos. Tiene finalidad informativa y no constituye asesoramiento juridico, auditoria RGPD ni dictamen legal profesional.

MMarco Seguridad | <https://mmarcoseguridad.com> | mmarco.seguridad@gmail.com | +34 656 33 93 55